

Reflections on the data protection compliance of AI systems under the EU AI Act

Balázs Hohmann & Gergő Kollár

To cite this article: Balázs Hohmann & Gergő Kollár (2025) Reflections on the data protection compliance of AI systems under the EU AI Act, Cogent Social Sciences, 11:1, 2560654, DOI: [10.1080/23311886.2025.2560654](https://doi.org/10.1080/23311886.2025.2560654)

To link to this article: <https://doi.org/10.1080/23311886.2025.2560654>



© 2025 University of Pécs. Published by Informa UK Limited, trading as Taylor & Francis Group



Published online: 17 Sep 2025.



Submit your article to this journal [↗](#)



Article views: 1810



View related articles [↗](#)



View Crossmark data [↗](#)



Citing articles: 1 View citing articles [↗](#)

Reflections on the data protection compliance of AI systems under the EU AI Act

Balázs Hohmann  and Gergő Kollár 

Department of Technology Law and Energy Law, University of Pécs, Pécs, Hungary

ABSTRACT

The European Union's Artificial Intelligence Act (AI Act) establishes a novel regulatory framework for AI systems, with far-reaching implications for data protection compliance. This study critically analyses the regulatory environment created by the Act and its interaction with the General Data Protection Regulation (GDPR), addressing whether it provides clearer compliance pathways or introduces additional burdens for developers. Using comparative legal analysis, the research finds that the AI Act supplements the GDPR through a risk-based approach that subjects high-risk AI systems to specific obligations. Key concerns include algorithmic opacity, bias, and legal uncertainty in profiling and automated decision-making. The analysis shows that the AI Act attempts to mitigate these risks by strengthening requirements on risk assessment, human oversight, and data governance. While the Act broadly aligns with GDPR principles such as transparency, fairness, and accountability, it also introduces new procedural and documentation duties that may increase compliance complexity. Overall, the study concludes that the AI Act constitutes a complementary yet stricter regulatory layer for AI-driven data processing, balancing innovation with fundamental rights protection and requiring joint interpretation with the GDPR to ensure coherent application.

ARTICLE HISTORY

Received 10 March 2025
Revised 15 August 2025
Accepted 4 September 2025

KEYWORDS

Data protection; artificial intelligence; AI Act; technology law

SUBJECTS

Data Protection;
Regulation; Information
Technology Law; Artificial
Intelligence

1. Introduction

Defining and delineating the phenomenon of artificial intelligence remains a complex task even today. Approaching it from different perspectives can yield divergent definitions without any of them being objectively incorrect. According to the definition provided by the AI Act, which will be discussed in detail later, AI refers to a machine-based system designed to operate at varying levels of autonomy and, after deployment, may exhibit adaptability (Alqodsi & Gura, 2023). According to the EU Artificial Intelligence Act of 2024, Article 5(1), such a system infers from the input it receives how to generate outputs—such as predictions, content, recommendations, or decisions—serving explicit or implicit objectives that may influence physical or virtual environments.. A somewhat simpler yet well-articulated definition describes artificial intelligence as ‘a set of technologies that combine data with algorithms and computing power’ (European Commission, 2020), typically to achieve process automation or augmentation. This formulation clearly reflects AI's technological complexity, multidisciplinary, and data-driven nature.

To refine the terminology more comprehensively, it is essential to clarify under what circumstances and why AI may be considered problematic. In other words, what indicators suggest that a given data processing activity is approaching the extreme negative end of the risk spectrum concerning individuals' rights and freedoms? The indicators that are indispensable for this analysis also represent recurring themes in this study: Big Data, datafication, cloud computing, and the Internet of Things (IoT). These

CONTACT Balázs Hohmann  hohmann.balazs@ajk.pte.hu  Department of Technology Law and Energy Law, University of Pécs, 48-as tér 1, Pécs, 7621, Hungary

© 2025 University of Pécs. Published by Informa UK Limited, trading as Taylor & Francis Group

This is an Open Access article distributed under the terms of the Creative Commons Attribution License (<http://creativecommons.org/licenses/by/4.0/>), which permits unrestricted use, distribution, and reproduction in any medium, provided the original work is properly cited. The terms on which this article has been published allow the posting of the Accepted Manuscript in a repository by the author(s) or with their consent.

concepts are closely tied to both data and algorithmic processes, yet they also warrant independent examination. Therefore, this study will address only the aspects most relevant to the topic. Additionally, a particularly pertinent issue in the context of AI systems is the generation of content (and thereby data) by AI, which also merits attention.

Big Data is no longer considered a novelty; some perspectives suggest that we have been living in the era of Big Data since at least 2012 (Lohr, 2012). Nevertheless, the lessons associated with this phenomenon remain highly relevant. The data underlying Big Data serve as key sources of usable data, which in turn require technological and legal management (Szőke, 2018). As the name suggests, Big Data enables the creation of vast data concentrations and provides a framework for computational processes carried out in uniquely complex (scalable) technological environments (ISO/IEC, 2019). It can be argued that artificial intelligence advances to a higher and potentially riskier stage due to the increasing scope and applicability of training databases. IoT primarily affects the input side by shaping data collection opportunities. However, the efficiency of networked, IP-based, sensor-equipped devices is significantly enhanced by algorithmic control. Datafication is a phenomenon describing the process of converting real-world events into data—predominantly digital data (Mejias & Couldry, 2019)—at an accelerating rate (Mayer-Schönberger & Cukier, 2013, pp. 91–99). This process is influenced by the proliferation of IoT devices, but it is also a broader aspect of the digitalization of social interactions (Southerton, 2020). AI-driven systems further amplify this transformation by facilitating, for example, personalized content recommendations.

Another noteworthy concept is cloud computing, which refers to the outsourcing of necessary hardware resources and their internet-based accessibility (Lehrig et al., 2015, pp. 83–92). In practice, this often takes the form of external storage services and capacity outsourcing. Beyond the data protection and security risks arising from high data concentration, cloud computing also presents enforcement challenges due to its inherently cross-border data-sharing structures (Trigueros-Preciado et al., 2013). Its significance lies in enabling the proliferation of sophisticated, algorithm-driven data management systems through low-cost access.

It is also crucial to address the rapidly growing phenomenon of data (typically textual or visual content) generation by AI systems (Proofed, 2023). The connection between AI and this domain is evident, but the associated risks are best illustrated by a specific concept: deepfake. This term refers to AI-generated or manipulated images, audio, or video content that resembles real individuals, objects, places, entities, or events and may misleadingly appear authentic to viewers. A deepfake is thus AI-generated or AI-modified content designed to create the illusion that an event occurred or that a person behaved or looked differently than in reality (AI Act, Art. 3, point 60). The creation of such deepfake content can lead to privacy violations, identity theft, misinformation, and the erosion of public trust, ultimately reducing transparency in both societal and interpersonal relationships. Addressing this issue falls under a specialized regulatory framework rather than general personal data protection norms. In Europe, the AI Act currently plays a central role in this regulatory effort.

This study seeks to answer the question of what new regulatory environment applies to artificial intelligence applications with the introduction of the AI Act. Within this topic, we specifically examine how the AI Act can reframe the requirements for AI applications that, in many respects, have been deemed problematic under the provisions of the GDPR. Additionally, we explore whether the introduction of the AI Act could provide a newly regulated pathway for software developers or, conversely, impose an additional regulatory burden on them. The research findings were obtained through a comparative analysis and systemic interpretation of the two regulatory frameworks.

The paper is organised to guide the reader through both the regulatory context and the critical issues that arise. Section 2 offers a comparative look at different regulatory models, with particular attention to the approaches of the European Union, the United States, and China. Section 3 turns to the perspectives of civil society and the main societal critiques of AI regulation. Section 4 examines the key data protection concerns associated with AI applications, including the black box phenomenon, algorithmic bias, and legal uncertainties around automated decision-making, and illustrates these issues through the example of the Dutch SyRI case. Section 5 brings together the key findings and puts forward recommendations for aligning the GDPR and the AI Act. The paper concludes by summarising the core arguments and reflecting on possible future directions for regulatory development.

2. The regulatory environment of advanced algorithms in Europe

2.1. The introduction of AI Act

Numerous attempts have been made to clarify the status of highly algorithmic systems at international, EU, and national levels (Zuiderveen Borgesius, 2020). Almost all have taken the form of soft law—guidelines or recommendations—such as the EU Commission's *White Paper on Artificial Intelligence* (European Commission, 2020). The first major exception was the EU's AI Act, which entered into force, at least partially, in 2024.

The Act, establishing harmonized rules on artificial intelligence and amendments to other legislative acts, aims to enhance the functioning of the internal market and promote the spread of human-centered and trustworthy AI. At the same time, it safeguards health, safety, and fundamental rights, as enshrined in the EU Charter of Fundamental Rights, against the adverse effects of AI systems (AI Act, 2024, Art 1).

The regulation adopts a horizontal, risk-based approach, setting minimum requirements to address AI-related risks and concerns (Schuett, 2024) while ensuring the enforcement of the public interest and a high level of protection rooted in European cultural and political foundations.

The regulation applies to AI system providers placing their systems on the market in the Union, AI users within the EU, providers and users whose AI-generated outputs are used in the EU, AI importers and distributors, manufacturers whose products incorporate AI systems, and individuals affected within the Union (AI Act, 2024, Art. 2). Therefore, the harmonized rules extend beyond AI systems developed within the EU to include those marketed or deployed there, creating an extraterritorial effect similar to the GDPR.

Given its complexity, the AI Act seeks to regulate an exceptionally intricate legal landscape. It is the first of its kind in the world in this form, although not the only such initiative (European Parliament, 2023). The so-called 'Brussels Effect' (Floridi, 2021), which describes the global influence of EU legislation, has already impacted South Korea, where a regulatory framework aligned with the AI Act will enter into force in January 2026 (Jethani, 2025).

From a global perspective, the regulatory landscape of AI is increasingly shaped by three dominant data governance models, corresponding to the major geopolitical blocs: the European Union, the United States, and China. These models represent divergent legal and policy approaches. Europe is marked by a strong emphasis on the protection of fundamental rights and a cautious, rights-based trajectory for AI development (Szöke, 2018). In contrast, the United States relies on a predominantly privatized model of regulation, where decisions regarding data governance are delegated to corporate self-regulation and market mechanisms. China, on the other hand, adopts a centralized, state-led model that prioritizes internal control and protection against external influences (Tóth, 2024, p. 24).

Beyond their theoretical distinctions, the real-world implications of these divergent models are evident in areas, such as international data flows and trends in artificial intelligence development. For instance, countries with stringent cross-border data restrictions—like certain high-restrictiveness jurisdictions in China—see AI innovation inhibited by more than half compared to those without such constraints (Sun & Trefler, 2023). Meanwhile, evolving geopolitical tensions between the US and China increasingly frame cross-border data flows as a matter of national security rather than mere economic activity, complicating cooperation and trust in transnational AI research and development (Zhang, 2025). In contrast, the EU–US Data Privacy Framework illustrates attempts to maintain data exchanges under clearer legal standards, though debates persist over its adequacy in protecting EU citizens' data privacy (Batlle & van Waeyenberge, 2024). Overall, these regulatory divergences risk fragmenting global data governance, hindering AI collaboration, and slowing innovation.

Both the US and Chinese approaches seek to export their models globally, shaping international norms to reflect their respective interests in data governance. Within this tripolar environment, the EU must assert its distinctive model of AI and data law. By integrating data use with fundamental rights protection through coherent legislation, the EU can secure a strong global position. The EU has already demonstrated a comprehensive and principled approach to data protection—particularly regarding personal data—and has shown determination to enforce these principles among market actors.

By contrast, the US and Chinese models emphasize the utility and exploitation of data, whether for economic or political purposes. This highlights a broader divergence in priorities: the EU follows a

rights-centric approach, while other actors often prioritize data use over protection. Yet neglecting either dimension—protection or use—risks systemic failure. This balance can be framed as both opportunity and responsibility—the carrot and the stick. Compliance with protective norms should entitle actors to benefit from productive data use, enabling public and private stakeholders to pursue innovation and societal goals. Without this balance, excessive data use can erode rights, while overprotection can stifle growth and innovation.

A coherent and harmonized EU legal framework could foster a uniquely advantageous environment for technological and social innovation. Such a framework would allow innovation to evolve in a measured yet dynamic manner, leveraging data while upholding individual and collective rights. In this context, EU law has a pivotal role to play in shaping the global trajectory of AI regulation.

External geopolitical dynamics could disrupt this balance. For example, a second Trump administration might derail the transatlantic regulatory alignment achieved in recent years (NOYB, 2025). Rolling back U.S. data safeguards could once again endanger transatlantic data transfer frameworks. Such developments may accelerate the ongoing ‘simplification revolution’ in EU policymaking (European Council, 2024), in which legislative ambitions are reduced for the sake of procedural efficiency. The European Commission’s decision to abandon the AI Liability Directive—officially in the name of simplification—may also reflect lobbying pressures from powerful U.S. stakeholders (Andrews, 2025).

For this study, certain provisions of the AI Act are especially significant, as its rules on algorithmic processes are closely tied to data processing. Key areas for further examination include newly introduced concepts and the main provisions on prohibited and high-risk AI systems.

The introduced concepts are extensive, elaborated across 68 points in Article 3 of the AI Act. Among these definitions, one finds the definition of the AI system itself, as well as those of key actors in the process. These include the provider (who develops, has developed, and places an AI system or general-purpose AI model on the market under their own name or puts it into operation) and the deployer (who uses an AI system under their supervision, with the exception of non-professional activities). Other potentially relevant actors in the supply chain are also defined, including the importer, distributor, and economic operator.

Particularly important are the definitions of specialized data concepts, which form a narrower subset compared to horizontal (general) data concepts, such as personal and non-personal data, or private and public data. These are specifically relevant to algorithmic processes and include:

- **Training data:** Data used to train an AI system by adjusting its learnable parameters.
- **Validation data:** Data used to evaluate the trained AI system and to configure its non-learnable parameters and learning process, including the prevention of underfitting or overfitting (Jabbar & Khan, 2014).
- **Test data:** Data used for the independent evaluation of an AI system to confirm its expected performance before it is placed on the market or put into operation.
- **Input data:** Data provided to or directly acquired by an AI system, based on which the system generates output.
- **Sensitive operational data:** Operational data related to activities aimed at preventing, detecting, investigating, or prosecuting criminal offenses, the disclosure of which could compromise the integrity of criminal proceedings.

Finally, the concept of the ‘general-purpose AI model’ is worth noting. Such systems are defined by their high level of generality and their ability to perform a wide range of tasks, regardless of how they are placed on the market. They can be integrated into various downstream systems or applications (Delacroix & Lawrence, 2019). However, models used exclusively for research, development, or prototyping before commercialization are excluded from this definition.

Notably, this concept aligns with a long-standing tripartite classification of AI development. According to this classification, the current dominant level is so-called narrow AI, which is capable of performing specific algorithmic tasks. The second level is general AI, which, as defined, has broad (practically human-equivalent) capabilities. The third level is so-called artificial superintelligence, whose essential characteristic is its general ability to surpass human cognitive abilities (Misuraca & van Noordt, 2020).

From this conceptual framework, one may conclude that the legislator is actively preparing for the widespread emergence and proliferation of general AI systems. It is important to note that contemporary generative artificial intelligences (e.g. ChatGPT) do not fall within this category of general AI. However, the classification of more advanced language models (e.g. GPT-4) remains a matter of debate (European Parliament, 2023).

2.2. The relevant provisions of the GDPR

Data law, through data protection, safeguards the fundamental human right to personal data protection (Mccorquodale, 1994) and influences technological and societal processes in multiple ways. Before examining the current legal framework, it is useful to outline a few general observations that remain valid regardless of the regulatory regime or historical period.

From a data law perspective, two crucial phases should be distinguished when applying AI systems to properly interpret the relevant interconnections. This is illustrated in Figure 1, which traces the progression of each phase.

The first phase is the development period, encompassing the process of building the system until it becomes functional. In this context, the link between data law and AI primarily concerns the source and legal assessment of the data sets used in development—namely, training data, validation data, and test data (Sartor & Lagioia, 2020). These datasets are essential for all machine learning methodologies based on artificial neural networks (including supervised, unsupervised, reinforcement, and deep learning), as they provide the necessary input data (Quiñonero-Candela et al., 2009). The relationship with data protection arises when these datasets contain personal data. While this is not inherently problematic, the primary challenge lies not so much in the legal classification of the data used for development—although

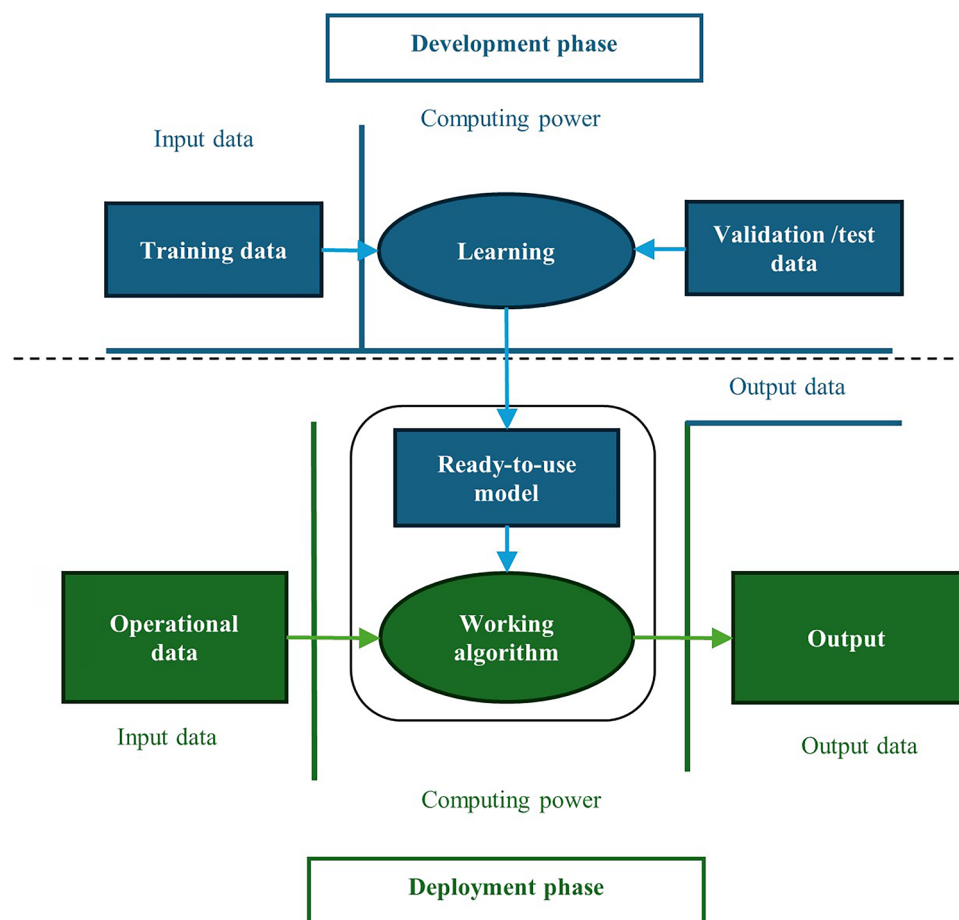


Figure 1. Data protection-relevant phases in the operation of AI applications.
Source: Compiled by authors.

its presence certainly necessitates stricter legal compliance—but rather in the source and precise knowledge of the data itself. Trends indicate that datasets for AI training largely originate from Big Data—vast collections of previously accumulated information (Chu et al., 2016). Consequently, in the development phase, the input data often remain opaque even to the developers, making them extremely challenging to handle. In such cases, it may not even be possible to determine definitively which data categories are involved (Lagioia and Sartor, 2020, pp. 15–30).

The second phase follows the completion of development and involves the deployment of the AI system, meaning its use in a real-world environment. Input data at this stage vary greatly depending on the type of system, so classification must be more general. Notably, the data source is not always Big Data, except when the AI's function involves analysing large datasets. The legal classification and source of data also depend on the AI's specific task. For example, an autonomous snowplough uses visual input from its environment to navigate, a grammar checker processes written text, and a hypothetical AI judge analyses case files to make decisions. These datasets can vary significantly and may or may not contain personal data, depending on the task at hand. However, a common feature at this stage—unlike during development—is a greater degree of transparency. A functioning AI system works with clearly identifiable input data relevant to its assigned task, making their legal classification more straightforward (e.g. a snowplough likely does not process personal data, while an AI judge almost certainly does). The data sources also become more tangible, linked directly to the operational environment (e.g. an airport runway for a snowplough, or legal proceedings and involved parties for an AI judge).

Consequently, concerns during deployment differ greatly from those in development. However, data protection rules may apply in both phases.

2.2.1. Requirements of GDPR

From this perspective, the General Data Protection Regulation, 2016, together with supplementary and clarifying national laws in EU Member States, contains several relevant provisions. However, due to the higher level of abstraction inherent in data law, none of these provisions explicitly regulate AI systems *expressis verbis*. The closest connection between the GDPR and AI systems lies in the concepts of profiling (GDPR, Art. 4, para 4) and automated decision-making (GDPR, Art. 22). Other relevant aspects include the GDPR's core principles, legal bases for processing, and data subject rights. Additional provisions worth noting are the requirements for data protection by design and by default (GDPR, Art. 25; see also AI Act Art. 3(52)), and the rules on processing for archiving in the public interest, scientific and historical research, and statistical purposes (GDPR, Art. 89).

The relevant legal provisions addressing concerns regarding AI-driven data processing will be examined in detail below. However, due to their particular relevance, we will first provide an overview of profiling and automated decision-making.

Under the GDPR, profiling means any form of automated processing of personal data that evaluates certain personal aspects of a natural person, particularly for the analysis or prediction of behavioral traits linked to their movements, habits, or characteristics (GDPR, Recital 71, Art. 4, para 4). In simpler terms, profiling identifies correlations in data and interprets them to create categories of people with shared attributes.

In contrast, automated decision-making is a more straightforward concept, referring to any decision based solely on automated processing of personal data. This issue is addressed in detail in Article 22 of the GDPR, but some general observations on profiling are necessary beforehand.

The GDPR restricts profiling rather than prohibiting it outright. These restrictions operate mainly through two mechanisms: data subject rights—such as the rights to be informed and to object—and core principles, notably purpose limitation and data minimisation. Profiling is lawful on any legal basis, provided that all other data processing requirements are fulfilled.

The policy rationale behind these restrictions is to mitigate the risks inherent in profiling, as it can, in certain cases, undermine an individual's ability to exercise self-determination. The rise of Big Data-driven systems has made it possible to construct increasingly complex profiles based on vast and virtually limitless amounts of data. The existence of such profiles can place those with access to this knowledge in a position of power, creating opportunities for misuse and severely endangering various aspects of an individual's private life.

3. Societal critiques of the AI Act from a data protection perspective

The adoption of the AI Act was preceded by significant public anticipation within the European Union (Cancela-Outeda, 2024). Based on societal feedback, European civil society formulated expectations for a high standard of fundamental rights protection, akin to those embodied in the General Data Protection Regulation (Thomaidou & Limniotis, 2025). Consequently, it is unsurprising that a number of civil society organizations have raised critical concerns about both the regulatory approach and the anticipated effectiveness of the AI Act (AlgorithmWatch, 2024; Amnesty International, 2023; European Disability Forum, 2024). According to several digital rights advocacy groups, the regulation leaves excessive loopholes and, as a result, ‘the AI Act fails to effectively protect the rule of law and civic space, instead prioritising industry interests, security services and law enforcement bodies’ (ECNL, 2023). Critics argue that the regulatory framework adheres too closely to a product safety logic, at the expense of a human rights-based approach (AccessNow, 2024; Svitych, 2025). This raises the risk that companies might comply in a purely formalistic, ‘check-the-box’ manner, without implementing meaningful changes to safeguard rights.

A recurring criticism concerns transparency and accountability: although the AI Act ostensibly improves these dimensions (e.g. through documentation and registration requirements), in practice public scrutiny may be undermined by the exceptions introduced. In 2023, the European Center for Not-for-Profit Law (ECNL, 2023) identified five key shortcomings in its analysis:

1. The prohibition of certain unacceptable AI practices may be rendered ineffective due to definitional ambiguities and exceptions, allowing some abusive uses to persist;
2. Risk assessments for AI systems rely primarily on self-assessment by providers or deployers, offering insufficient guarantees for the protection of fundamental rights;
3. While the inclusion of fundamental rights impact assessments (FRIAs) is welcome, civil society groups argue that the requirements lack robustness—there is no mandatory involvement of external experts, and no obligation to prevent identified risks, only to devise mitigation plans;
4. National security-related uses of AI are subject to overly lenient rules, which may result in fundamental rights being left virtually unprotected in such contexts;
5. There is no meaningful involvement of civil society in the enforcement or oversight of the regulation—language mandating participation by civil experts in assessing high-risk systems was removed during the final legislative negotiations. In the absence of such provisions, affected communities and independent experts may be excluded from oversight processes, further weakening democratic accountability.

Another point of contention concerns the lack of effective safeguards against algorithmic discrimination. Although the AI Act requires providers to ensure data quality and minimize bias, critics argue that these provisions lack specificity and enforceability (Chiappetta, 2023). Civil society coalitions have urged that the AI Act explicitly reference EU anti-discrimination legislation—such as the Racial Equality Directive—when AI systems make or influence decisions, and have called for mandatory independent audits to identify and mitigate bias. However, these proposals are only indirectly reflected in the final text, raising concerns that the regulation may fall short in addressing structural discrimination (AccessNow et al., 2024).

Moreover, it has been argued that although the AI Act aims to enhance both regulatory oversight and fundamental rights protection, it may paradoxically weaken both in practice. One particularly problematic aspect is the set of exceptions provided to developers and deployers of AI systems, which allow deviations from the general rules in certain circumstances. These exceptions raise significant fundamental rights and data protection concerns.

The AI Act formally applies to AI systems used in law enforcement, border management, and migration, but introduces special rules and exemptions for these sectors. While the regulation classifies certain practices—such as real-time biometric identification in public spaces and predictive policing—as ‘unacceptable risk’ and thus prohibited, the final text includes carve-outs for law enforcement authorities (Borak, 2024). For instance, real-time remote biometric identification in publicly accessible spaces is banned in principle, but permitted in narrowly defined exceptional cases (e.g. prevention of terrorist attacks, search for missing persons, or locating abducted children). This means that, with proper judicial

or administrative authorization, police authorities may still deploy such technologies, despite the European Parliament's earlier proposal for an outright ban. A similar dynamic applies to predictive policing: although the final AI Act prohibits systems that assess the likelihood of criminal offenses based on profiling, civil society groups warn that vague definitions may leave room for continued use of certain predictive tools (AccessNow, 2024; AccessNow 2024).

Transparency obligations are also relaxed for authorities in these sectors. Under the AI Act, high-risk AI systems must be registered in a public EU database (AI Act, Art. 71), with key information disclosed—including purpose, legal basis, and a summary of the fundamental rights and data protection impact assessment (AccessNow, 2024, p. 2). However, law enforcement, migration, and border management authorities secured an exemption: they are only required to submit limited data, and only to a non-public section of the database (Art. 49, para. 4). Crucially, important elements—such as characteristics of the training data—will not be publicly accessible. As a result, civil society and independent watchdogs will face serious barriers to oversight and accountability in applications that pose significant risks to fundamental rights (Amnesty International, 2023; Article 19, 2024). Moreover, the regulation allows further exemptions for 'national security reasons' (AI Act, Art. 2, para 3), a vague clause that is frequently invoked to justify disproportionate uses of surveillance technologies. Taken together, these provisions mean that AI systems deployed in law enforcement and migration contexts are treated as a special case: they are formally designated as high-risk, yet receive preferential treatment with regard to transparency and external scrutiny. Although lawmakers justified these compromises by citing national security and public order concerns, many critics argue that this creates a dangerous opacity precisely in the domains where fundamental rights are most at stake (AccessNow, 2024, pp. 7–8).

While several of these concerns were raised during the legislative process, the final text of the AI Act reflects only partial concessions to civil society demands. For example, limited transparency obligations for law enforcement and migration authorities were retained despite calls for their removal, and proposals for mandatory external oversight or explicit references to EU anti-discrimination law were not adopted (Aszódi, 2025). The European Commission has since issued interpretative guidance on certain provisions—such as those on the definition of an AI system and on prohibited AI practices, and committed to monitoring their implementation, but no formal amendments have been introduced in response to these criticisms (European Commission, 2025a, 2025b).

4. Concerns—artificial intelligence applications in light of data protection requirements

4.1. General concerns

The core objectives of data protection law and the AI-driven—particularly Big Data-based—data processing mechanisms are inherently at odds (Cohen, 2013). These AI systems, by their very operational nature, require access to the largest possible datasets. As a result, data collection often overlooks restrictions, such as purpose limitation, data minimization, and storage limitation (Mayer-Schönberger & Cukier, 2013). This conflict stems from the fact that, at the time of collection, it is often unnecessary or impossible to fully foresee the data's potential applications or utility. By design, AI systems uncover unknown correlations and generate new conclusions, shaping their own use cases in the process. Thus, the primary and most fundamental data protection concern stems from the collision between regulatory policy objectives and the technological principles underlying AI systems.

However, this does not mean that the GDPR is fundamentally incompatible with Big Data-driven AI systems. Rather, resolving this conflict requires careful case-by-case analysis to balance compliance with innovation (Sartor & Lagioia, 2020, pp. 44–45).

Another structural concern that pervades AI systems is the so-called black box phenomenon, an intrinsic characteristic of many advanced AI models. As philosopher Bruno Latour observed, '*when a machine runs efficiently ... one need focus only on its inputs and outputs and not on its internal complexity*' (Latour, 1999, p. 304)—a definition that traces the concept's deep roots in systems theory and science studies. This phenomenon arises when the causal link between input and output becomes opaque to external observers. While the input data and the generated output are identifiable, the cause-and-effect

relationship between the two—why a particular result was reached based on given data—often remains inaccessible or extremely difficult to reconstruct (Misuraca & van Noordt, 2020).

From a data protection perspective, this poses fundamental issues at the level of legal principles due to the lack of transparency. It also creates major obstacles to enforcing data subject rights and ensuring legal remedies for those affected by automated processing. Beyond data law, such opacity can threaten other fundamental rights, including human dignity and equal treatment, and may breach sector-specific or procedural rules requiring transparency (Mank, 2017).

A third major concern permeating the entire system is algorithmic bias, which refers to biased or discriminatory AI outputs resulting from errors in software design, biased training data, or distortions in dataset composition. In many cases, such biases are unintentional on the part of developers. However, especially when using historical datasets (Edwards & Veale, 2018), AI systems may amplify long-standing but previously unrecognized discriminatory patterns embedded in societal or institutional practices.

From a data protection perspective, this issue has serious legal consequences, irrespective of intent or the origin of bias. A decision made based on a discriminatory AI algorithm will almost inevitably constitute unlawful data processing, as it results in unjustified disparate treatment of individuals. Moreover, algorithmic discrimination is not just a data protection concern—it may also violate fundamental rights, such as non-discrimination and equality before the law. The potential flaws of such systems are illustrated by the SyRI (System Risk Indication) algorithm used by the Dutch government from mid-2014. The system was intended to detect social benefit fraud by combining personal data from various government databases—such as tax, housing, education, and social welfare records—to create risk profiles that could identify suspected fraudsters (Braun, 2018).

The system's operation raised several concerns. Both the functioning of SyRI and the datasets it relied on were not publicly disclosed, leaving individuals unaware of which personal data might lead to suspicion. It was applied mainly in low-income, marginalized neighborhoods, disproportionately targeting these communities and risking reinforcement of structural discrimination. Compounding these issues, SyRI failed to detect any new fraud cases, calling into question its effectiveness and proportionality.

In response, civil rights organizations brought legal action against the Dutch state. In 2020, the District Court of The Hague ruled that SyRI violated human rights, in particular Article 8 of the European Convention on Human Rights, which guarantees the right to privacy (AlgorithmWatch, 2020).

This case illustrates a broader point: any legal flaw in an AI system's data lifecycle is likely to result in unlawful operation and data processing. The legality and quality of input data must therefore be ensured at every stage of the AI lifecycle. Transparency is equally essential to allow for legal scrutiny of system operations. Finally, even when legal requirements are formally met, the suitability of the system for its intended purpose must be evaluated. If the system fails to achieve its goals effectively—as in the case of SyRI—the principles of necessity and proportionality are difficult to justify. While the SyRI judgment did not have a direct legislative impact on the drafting of the AI Act, it serves as a conceptual parallel that underscores the regulation's emphasis on proportionality, transparency, and fundamental rights safeguards in high-risk AI contexts.

4.2. Fundamental principles

The GDPR's system of fundamental principles serves as a guide to resolve interpretative difficulties and fill potential legal gaps, and in this regard, it fulfills its role exceptionally well. Practical experience confirms that understanding the real expectations of data protection law requires first grasping its core principles. Accordingly, a detailed examination of AI-related concerns should also start here. The essential content of these principles has been widely analyzed in legal scholarship; therefore, this section focuses specifically on aspects related to AI systems. Under the principle of lawfulness, fairness, and transparency, data processing is lawful only if it meets general legal requirements—a concept that can be seen as 'parallel lawfulness,' meaning a breach of sectoral rules (e.g. AI law) automatically constitutes a breach of data protection law. This imposes a continuous compliance burden on data controllers, which, given the opaque nature of AI systems, can lead to significant challenges. With regard to fairness and transparency, AI systems raise particular concerns, as a distinction must be made between informational fairness (formal compliance, e.g. providing a privacy notice) and substantive fairness (ensuring that the provided

information is understandable) (Sartor & Lagioia, 2020, p. 44). A common concern is that there is no guarantee data subjects can understand the information provided under the duty to give notice, meaning the process may be formally fair but not substantively so. This issue is particularly pronounced in this field, as the internal operation of an AI system is—unsurprisingly—difficult for laypersons to understand, making fairness challenging to achieve even with the best intentions (Wachter et al., 2017). Recital 71 of the GDPR makes fairness an obligation of the controller, yet unfair processing may remain hidden even from the controller—due to the black box phenomenon or other factors—allowing unlawful conditions to persist for long periods. In addition to violating fairness, this also has a detrimental impact on transparency.

The principle of purpose limitation is problematic for large-scale data stockpiling and reprocessing of data of unknown origin (Clifford & Ausloos, 2018), especially when the controller does not know the data's original purpose. The GDPR provides an important exception to this principle by establishing a presumption of compatibility in Article 5(1)(b), allowing further processing for public interest archiving, scientific and historical research, or statistical purposes under Article 89(1). Assessing the applicability of this exception is inherently difficult with data of unknown origin, and even when the original purpose is known, compatibility still requires careful examination. The Article 29 Working Party has emphasized that in this context, key factors to consider include the distance between the original and new purposes, the relationship between the new purpose and the data subject's expectations, the nature of the data and its impact on the individual's interests, and the safeguards implemented by the data controller to ensure fair processing (Article 29 Data Protection Working Party, 2013). A particular concern in this regard is that personal data entering training datasets under unstructured conditions during the development phase may result in adverse consequences for specific individuals or groups. A clear tension exists between the principle of data minimization and Big Data-based AI systems. As previously discussed, the current approach to resolving this issue relies on a form of purpose-driven legal interpretation.

The principle of data minimization is not an explicit numerical requirement but rather applies as a legal principle to all data processing activities. Consequently, the notions of adequacy, relevance, and necessity must be interpreted in a proportionate manner relative to expected benefits and risks, ensuring that the requirement remains realistically applicable. Under this interpretation, the dataset may be expanded as long as its contribution to achieving the intended purpose outweighs the risks posed by the inclusion of new data (Sartor & Lagioia, 2020, pp. 47–48).

The concerns regarding the principle of accuracy are less abstract, as it is evident that inaccurate data cannot achieve the intended purpose. During the development phase, inaccuracies may lead to flawed logical relationships, while during deployment, they may result in incorrect conclusions and erroneous decisions, which, in turn, affect the overall lawfulness of the process. A high degree of inaccuracy may ultimately violate the principle of purpose limitation by rendering the process incapable of fulfilling its intended function.

The principle of storage limitation remains a source of tension between the data stockpiling approach of AI systems and the expectations of data law. This issue is particularly concerning in cases where, during the development phase, the origin of input data—and thus the time of its initial recording—is unknown. Another significant factor is that in a Big Data-driven approach, while the value of data may diminish over time, it does not disappear, as cross-analysis with newer data can yield additional insights (Mayer-Schönberger & Cukier, 2013, pp. 50–91). As a result, the notion of limited storage duration is fundamentally alien to and practically incompatible with the logic of Big Data.

4.3. Legal bases

The legal basis represents the authorization for processing personal data; therefore, every data processing operation must have one (and only one) legal basis. The decision-making process regarding legal bases is a complex legal and professional task, as outlined in Figure 2. Without this, the lawfulness of data processing conducted by AI cannot be ensured.

A positive aspect of the legal basis of consent is that it can be applied in both the development and deployment phases, but in each case, caution is required. In the case of reused databases, it is possible that the original consent obtained for the initial data processing was broad (so-called broad consent, see

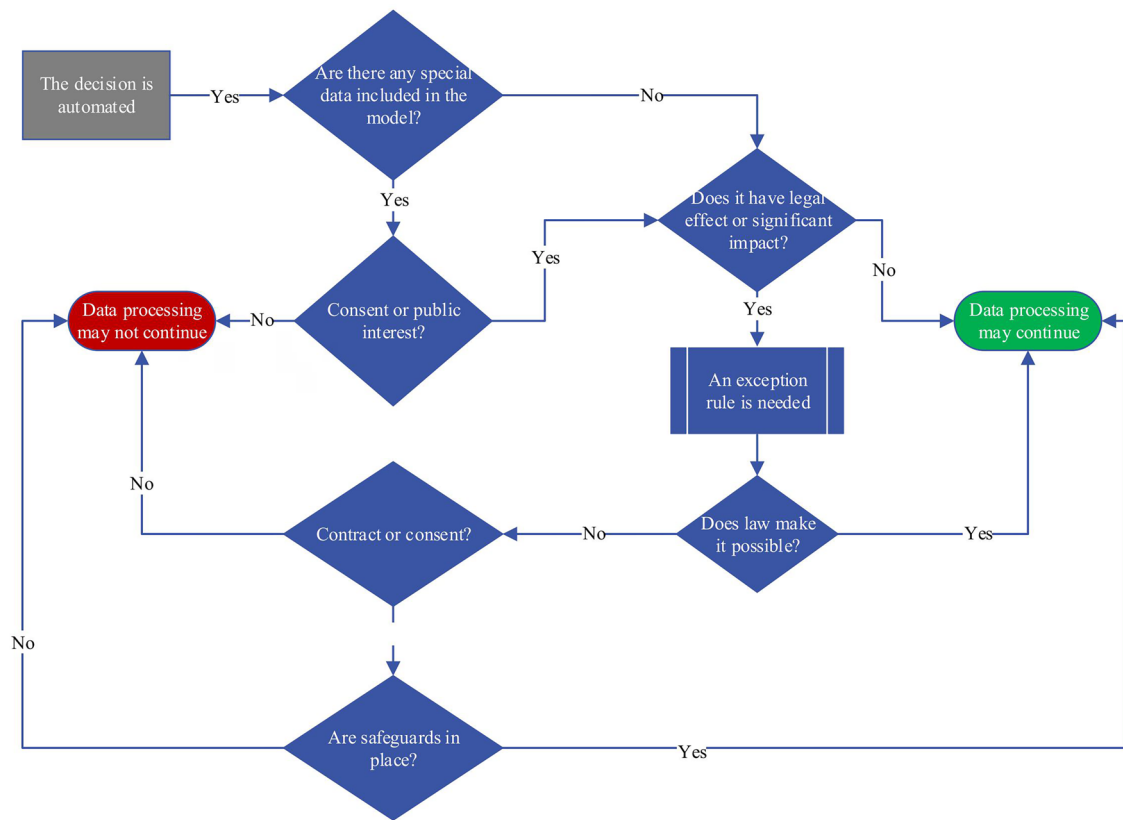


Figure 2. The process of assessing data protection compliance based on GDPR requirements.
Source: Compiled by authors.

Maierà, 2023), meaning that it may cover the use of previously provided data for new purposes that do not harm the data subject's interests. However, even in such cases, there remains the question of whether the data subject is truly capable—despite having received the necessary information—of understanding the potential consequences. This is why the notice-and-consent approach has long been criticized (Solove, 2013). The legal basis for processing is somewhat more secure during the deployment phase if the data controller obtains proper consent before initiating data collection. In both scenarios, ensuring that consent meets all legal requirements is a major challenge. However, in the latter scenario, the process is somewhat easier, as the data controller does not need to rely on the lawfulness of another controller's previous processing. Another critical factor concerning this legal basis is the data subject's right to withdraw consent and request data deletion at any time. The exercise of either right could disrupt automated processes, and in extreme cases, it may render the AI model unusable. When using necessity for contract performance as a legal basis, the key issue is necessity itself, as it applies only if algorithmic processing is directly and closely tied to fulfilling contractual obligations. Another limitation is that the data subject must be a contracting party; if they are not, this legal basis cannot be applied. In the development phase, this legal basis is likely only applicable in a very narrow market segment, but during deployment, it may be possible to integrate the algorithm itself into the contractual provisions governing the relationship. If a statutory obligation is clearly defined, the data controller has no discretion and must carry out the processing, regardless of whether algorithmic tools are used or not. The legal basis of vital interests is generally of limited applicability, and the same holds true for AI systems. The threat must be real and imminent, meaning that this legal basis is less applicable for addressing general risks. To ensure lawfulness, EU or Member State law is required (which may not always exist), and necessity and proportionality must be thoroughly assessed.

Nevertheless, this legal basis is likely the most suitable for the public sector when introducing and operating AI systems. Similar to the previous legal basis, legitimate interest provides a flexible and widely applicable legal basis for AI systems, but this time with particular relevance to the private sector. In the

absence of explicit legal provisions, a well-thought-out technical framework is required, and the data controller must build the entire balancing test—assessing interests, necessity, and proportionality—from scratch, which can be a significant challenge.

4.4. Data subject rights

Regarding data subject rights, it is important to note that most of them affect data processing, regardless of which specific right is exercised. The GDPR, however, explicitly links profiling and automated decision-making to the rights to information, access, and objection. The GDPR establishes specific requirements for the content of information related to profiling and automated decision-making, including the fact of processing, the logic involved, its significance for the data subject, and the expected consequences (GDPR 13(2)(f), 14(2)(g), 15(1)(h)). One of the concerns in this regard is that when using repurposed datasets, the original data subjects may not receive any notification, meaning they cannot exercise their right of access. Another issue is the ambiguity regarding whether general or individualized, personalized explanations about the applied logic are required (Sartor & Lagioia, 2020, pp. 56–57). The obligation to provide information, particularly in innovative fields, may also conflict with the data controller's perceived or actual business interests, often creating a fundamental conflict of interest between the controller and the data subject. A key question regarding the right to rectification is whether objections concerning inaccuracies can only be raised concerning the original source data or also against new data generated by the AI system itself. This issue also arises with other data subject rights, so the considerations outlined here apply equally. In certain cases, the data controller is obliged to delete personal data in its possession. The greatest interpretative difficulty is determining the scope of data to be deleted, as—similar to rectification—it is unclear whether this right applies only to input data, only to output data, or both. In the first case, deletion would theoretically be unproblematic, but the consequences could be significant, as without input data (e.g. validation data), the accuracy of the AI system cannot be verified. For output data, it is not always clear whether they still qualify as personal data (Sartor & Lagioia, 2020, p. 57), which depends heavily on the AI system type and the complexity or ease of re-identification testing. Similar concerns also arise with the right to data portability under Article 20 of the GDPR. The right to object explicitly references AI-related concepts, granting data subjects the right to object at any time, on grounds relating to their particular situation, to processing under Article 6(1)(e) or (f), including profiling based on these provisions. Additional rules apply to direct marketing, research, and statistical data processing. The significance of these distinctions becomes evident in practice, as both categories frequently involve AI systems (Sartor & Lagioia, 2020, pp. 57–59). In the case of direct marketing, stricter rules apply, as the right to object is absolute, meaning the controller cannot invoke compelling legitimate grounds to override the objection. The GDPR explicitly associates profiling with direct marketing, meaning the stricter objection rules also apply to profiles created for this purpose (GDPR, Art. 21 para 2–6). By contrast, a more lenient approach applies to research and statistical purposes, as objections are not allowed if the processing is necessary to perform a task in the public interest. The result of a successful objection is the same as for a deletion request: the data can no longer be processed, and the associated concerns mirror those described for deletion.

4.5. The provisions of Article 22 of the GDPR

The legal provision referenced in the subheading represents the closest connection to AI systems, as it contains rules on automated decision-making and related profiling. At the outset, it can be stated that Article 22 imposes a complex and strict regulatory framework, presenting a significant challenge for organizations developing and deploying AI systems. These stricter provisions are justified by the heightened risks that algorithmic processes pose to privacy, human dignity, and decision-making autonomy—values protected at the fundamental rights level by data law (Zarsky, 2013). Only profiling that forms the basis for an automated decision falls within Article 22's scope—profiling itself remains permitted unless the automated decision based on it is prohibited (Article 29 Data Protection Working Party, 2018). For the sake of completeness, each paragraph of Article 22 will be examined separately.

According to Article 22(1), the data subject has the right not to be subject to a decision based solely on automated processing—including profiling—if the decision produces legal effects concerning them or similarly significantly affects them. Due to the wording of the GDPR, it is not entirely clear whether this provision establishes a right for the data subject or an obligation for the data controller. However, any obligation imposed on one party necessarily gives rise to a corresponding right on the other, ensuring enforceability (i.e. compliance with the obligation), leading to a similar practical outcome regardless of interpretation.

Moving forward, Article 22(2) outlines three exceptions to the general prohibition under paragraph (1). This means fully automated decisions may still be made, even with legal or similarly significant effects, if one of the exceptions applies. The exceptions are as follows:

- The decision is necessary for entering into or performing a contract between the data subject and the data controller;
- The decision is authorized by Union or Member State law applicable to the data controller, which also lays down appropriate measures to safeguard the data subject's rights, freedoms, and legitimate interests; or
- The decision is based on the data subject's explicit consent.

Further elaborating on the reasoning behind Article 22, the Regulation also establishes additional strict safeguards to protect data subjects when one of the first or third exceptions applies. In such cases, the data controller is obliged to implement protective measures. The GDPR specifies a minimum set of safeguards, granting the data subject the right to request human intervention, express their viewpoint, and contest the decision (see AI Act, Art. 14).

A final restriction is introduced in Article 22(4), which states that decisions made under the exceptions cannot be based on special categories of personal data (GDPR, Art. 9, para 1). However, even this prohibition is subject to exceptions if specific conditions for processing special categories of data are met—either the data subject has given explicit consent or the processing is necessary for reasons of substantial public interest (GDPR, Art. 9, para 2). Additionally, further requirements dictate that appropriate safeguards must be implemented to protect the rights, freedoms, and legitimate interests of the data subject.

5. The provisions of the AI regulation and potential impact on data protection concerns

The following table—Table 1, as below—presents the provisions of the AI Regulation that can be interpreted as attempts to address the concerns previously identified, thereby holding significant relevance in terms of data law, even though they originate from a regulatory framework outside of traditional data protection law. These provisions establish a strong connection with data protection principles and aim to mitigate risks associated with AI-driven data processing. It is important to note that the AI-related requirements outlined here apply exclusively to high-risk AI systems. For AI systems classified at lower risk levels, compliance with these provisions is not mandatory.

6. Conclusion

A review of the GDPR's provisions indicates that current data protection law does not seek to prohibit the development or application of AI systems in any form. Moreover, there are interpretative approaches that, when applied, ensure that data controllers within the European Union do not face competitive disadvantages compared to their counterparts in other parts of the world. Ideally, AI development can progress in a sustainable manner within an environment that fosters innovation while respecting fundamental rights. The AI Regulation plays a crucial role in this process by effectively complementing and cooperating with existing data law provisions. Thus, concerns can be addressed through the combined interpretation of the GDPR and the AI Regulation, with the right approach and firm commitment, while risks can be mitigated.

One of the key concerns in data law relates to conflicts with fundamental principles. The principles of transparency, purpose limitation, data minimization, and storage limitation prescribed by the GDPR often

Table 1. Relevant articles in the AI Act concerning data protection compliance.

Article	Provision	Short content	Data protection significance
Art. 9	<i>Risk Management System</i>	This system can be conceived as an iterative process without interruption, designed and operated for the entire lifecycle of a high-risk AI system, requiring regular and systematic review and updating. The primary evaluated circumstances concern health, safety, and fundamental rights (AI Act, recital (65)).	Declares a risk-based approach typical in data law, and reinforces legal compliance requirements for outputs.
Art. 11	<i>Technical Documentation</i> for system deployment or commissioning, and its ongoing maintenance	Documentation must be compiled to prove that the AI system meets legally defined requirements and enables those with authorization to access clear and understandable information necessary for its evaluation.	A provision serving transparency, informatively supporting fair procedures by requiring documentation in 'clear and comprehensible form', but with appropriate content for expert organizations/authorities.
Art. 12	<i>Record Keeping</i> , continuously recording automatically occurring events during the system's lifecycle (logging)	Logging capabilities must enable identification of at least situations that may pose risks or result in significant modifications to the AI system, and facilitate post-market tracking.	Aligns with data protection accountability and data security requirements, while supporting transparency.
Art. 13	<i>AI System Transparency and Reporting</i>	AI systems must be designed and developed with sufficient operational transparency to enable users to interpret the system's output and use it appropriately. This must be implemented in practical digital format or other usage instructions that are concise, comprehensive, accurate, and unambiguous, containing information relevant, accessible, and understandable to users.	A provision serving substantive fairness by establishing an interpretability obligation practically comprehensible for almost anyone. The information provided to users can also function as stakeholder notification.
Art. 14	<i>Effective Human Supervision</i> during system usage	Aims to prevent or minimize risks affecting health, safety, or fundamental rights. This can be achieved through measures built into the system by the provider or implementable by the user. Such measures must be proportionate to the AI system's risks, autonomy level, and usage context.	Serves to mitigate potential dysfunctions in algorithmic processes, provide effective legal remedies, incorporate risk-proportionate perspectives from data protection law, and reinforce substantive fairness.
Art. 15	<i>Accuracy, Stability and Cybersecurity</i>	AI systems must be designed and developed to achieve appropriate levels of accuracy, stability, and cybersecurity, consistently performing throughout their entire lifecycle.	Aligns with data protection principles like purpose limitation, data minimization, and accuracy. Demands system impartiality and absence of algorithmic bias. Cybersecurity inherently requires data integrity and confidentiality.
Art. 27	<i>Fundamental Rights Impact Assessment</i> for certain high-risk AI systems	The assessment must cover: application process description, usage period and frequency, identifying natural persons and groups affected, specific harm risks, describing human supervision measures, actions to be taken if risks materialize.	Shows strong connection with GDPR Article 35 data protection impact assessment. The parallel is strengthened by AI Act Article 27(4), which requires complementary assessment if a data protection impact assessment has already been conducted.
Art. 16	<i>Other Obligations</i>	Similar to data controllers' obligations, at least name and contact information must be provided by the service provider Introduction and maintenance of QMS typically established and maintained by standards	Can serve transparency and clear delineation of responsibility areas. Enables standardization of compliance practices, facilitating more efficient verifiability and comparability among service providers.

(Continued)

Table 1. Continued.

Article	Provision	Short content	Data protection significance
Art. 43		Conducting conformity assessment procedure before AI system deployment, verifying provider's compliance through external or internal auditing	Reinforces accountability through unified and independent procedure verification.
Art. 47		Providers must prepare EU conformity declarations documenting global requirement compliance, specifically for relevant national authorities	Represents a mechanism of regulatory control for accountability.
Art. 48		Must display CE marking of compliance	Supports user-based informed decisions, ultimately contributing to safe self-determination.
Art. 49		Registration in EU database maintained by the Commission for high-risk AI systems	Increases external control and public trust in legally operated services.
Art. 20		If the system does not comply or is likely non-compliant, immediate corrective actions are required, potentially including withdrawal, decommissioning, or recall	Similar to unlawful data processing, requires proactive addressing of non-compliance, introducing a quasi 'self-reporting' system.
Art. 10	<i>Data and Data Governance: Training, Validation, and Test Datasets</i>	High-risk AI systems must undergo appropriate data governance and management practices	
Art. 10(2)(b)-(c)	<i>Source Database Legality</i>	Data collection procedures, data origin, and original purpose for personal data must be clarified	Aims to mitigate knowledge gaps regarding data sources
		Necessary data preparation operations must be performed (e.g. annotation, labeling, cleaning, updating, enrichment)	Closely related to data minimization and accuracy principles
Art. 10(2)(d)	<i>Expected Impact Assessment</i>	Hypotheses must be formulated, especially regarding information the data should measure and display	Comparable to purpose limitation, supporting the legitimacy of data operations
Art. 10(2)(e)	<i>Source Database Relevance</i>	Ensuring necessary dataset availability, evaluating quantity and suitability	Connected to multiple principles: purpose limitation, accuracy, data minimization, limited storability
Art. 10(2)(f)	<i>Dysfunction-Free Operation</i>	Must investigate all potential biases likely to impact health and safety, negatively affect fundamental rights, or lead to discrimination prohibited by EU law, especially when output data influences future operation inputs	Primarily related to algorithmic bias prohibition, consequently ensuring compliance with underlying legal requirements like equal treatment

Source: Compiled by the authors.

prove difficult to enforce in Big Data-driven operations, where significant information gaps exist regarding the origin of input data. Additionally, algorithmic bias and the black box phenomenon present further challenges. Given the GDPR's requirement for parallel lawfulness, these anomalies can easily lead to unlawful data processing.

Concerns also arise regarding legal bases for processing. The lawful processing of data with unknown origins or repurposed for uses beyond the original collection purpose is questionable, as a valid legal basis may not always be established. The enforcement of data subject rights presents additional challenges, particularly when data subjects are unknown or difficult to identify, making it impossible to provide the necessary information and thereby hindering the exercise of their rights. Furthermore, it remains unclear whether such rights apply solely to source data or also to newly generated data produced by the AI system. Another issue is that if a data subject exercises their rights—such as the right to erasure, objection, or rectification—the removal of input data from the AI system may prevent the verification of its accuracy, while the deletion of output data may render the entire process meaningless.

Analysis suggests that the development phase is particularly sensitive, though certain mitigating measures and the provisions of the AI Regulation offer some balance—albeit only for high-risk AI systems. The deployment phase begins with more favorable conditions, yet compliance with existing data protection requirements and the management of persistent risks remain challenging. Regulatory practice

indicates that higher levels of compliance are generally expected from data controllers when dealing with algorithmic processes.

Both the development and deployment phases require the implementation of IT and administrative measures to facilitate compliance and reduce risks. In the development phase, one of the greatest—but not the only—risks lies in handling input data. Legal solutions to this issue include clarifying the source of the data and identifying personal data. One approach is to exclude personal data at the input stage, ideally in such a way that the data controller never interacts with it. If this is not feasible, the legality of data processing should at least extend to anonymization. If anonymization is successfully applied, the data controller may process the resulting non-personal data independently of GDPR requirements. If neither the exclusion nor anonymization of personal data is possible, an alternative solution is to use external databases that have been lawfully prepared by third parties for further processing. Ensuring legal compliance while opting for less burdensome solutions may offer long-term market advantages, though associated costs may be a significant factor.

The development phase plays a central role in ensuring compliance with data protection requirements. In practical terms, the extent to which developers adhere to these requirements largely determines the compliance of end users. Key factors include the legal status of input data, the purposes for which it is used (particularly for training), and the methodologies applied. Accordingly, developers bear responsibility for guaranteeing the legal integrity of datasets and for mitigating algorithmic bias and opacity (the so-called black box phenomenon) through appropriate technical and organizational measures.

Developer obligations thus lie at the intersection of the GDPR and the AI Act. This regulatory convergence increasingly demands robust transparency and explainability: system documentation and notification obligations from both frameworks may create an expectation that systems be not only technically sound but also intelligible to non-expert users. For instance, the mere provision of source code is insufficient unless accompanied by meaningful explanation comprehensible to laypersons.

Equally critical is the rigor of testing required under Data Protection Impact Assessments (DPIAs) and Fundamental Rights Impact Assessments (FRIAs). These tasks intersect with a broader set of cybersecurity and data governance obligations, not only under the GDPR and the AI Act, but also under complementary frameworks, such as the NIS2 Directive and the Cyber Resilience Act (CRA).

Beyond these minimum legal requirements, developers may adopt further measures to promote downstream compliance. One of the most effective strategies is to design the software environment in accordance with the principles of *privacy by design* and *by default*, as articulated in Article 25 of the GDPR. *Privacy by design* entails the systematic integration of data protection safeguards into the architecture and governance of AI systems from the earliest stages of development. *Privacy by default* emphasizes lawful and protective defaults in system behavior and configuration. This principle is particularly relevant in the development and procurement phase, where embedding compliance mechanisms directly into systems reduces the likelihood of user error or malicious exploitation and lowers reliance on external organizational controls.

In conclusion, shortcomings in the development phase can easily translate into non-compliance during deployment. In light of this, development practices that fail to prioritize legal and ethical design may not only increase systemic risk but also prove commercially disadvantageous in EU markets, where regulatory scrutiny and customer expectations regarding data governance are both high.

In the deployment phase, the diversity of real-world scenarios complicates the search for appropriate solutions, yet there are no legal barriers to ensuring AI systems' compliance. Achieving legal compliance, however, is a complex task that requires careful and consistent oversight throughout the process. Data subjects must be identified and informed at the point of data collection or reception, and their ability to exercise their rights must be continuously supported. Transparency must be ensured both in an informative and substantive manner, even if data is later anonymized. The legal basis and purpose of processing must be clearly defined before the processing begins. Article 22 of the GDPR currently serves as the primary regulatory framework for AI systems in data protection, making its compliance a high priority. Furthermore, factors that indirectly impact data processing—such as the black box effect and algorithmic bias—must be addressed through legal, technical, or ethical measures to ensure compliance with data protection (and AI law) requirements.

While the implementation of these measures may increase costs and, in some cases, hinder certain innovations, they remain essential and justified when considering the values they seek to protect. It is uncertain whether rapid, high-risk advancements will retain their advantages in the long term. Moreover, the legality and security of data-driven processes could become as significant as, for example, the beneficial effects of healthy food on the human body. While some may not prioritize legality and security, these factors generally represent value-enhancing attributes in most market segments, and they are likely to become increasingly important in the field of data-driven operations as well.

This is particularly relevant given that the AI Act includes a complex, multi-tiered system of periodic review and evaluation (AI Act, Art. 112). The Commission is required to conduct both general and thematic assessments at varying intervals—annually, every three or four years, and in some cases by 2031—covering issues, such as the scope of prohibited and high-risk AI practices, the effectiveness of transparency obligations, the adequacy of enforcement mechanisms, and the institutional capacities of national authorities. These evaluations may lead to legislative amendments where appropriate. To support this process, the Regulation also mandates the development of an objective and participatory methodology to assess changing risk levels and identify new systems requiring regulatory attention. By establishing such structured, recurring mechanisms, the AI Act opens a regulatory pathway for addressing ongoing concerns raised by civil society, particularly in relation to fundamental rights, market fairness, and the need for transparency and accountability in AI deployment.

It is to be hoped that these voices will be heard by the European legislator in due time.

Yet hope alone is insufficient. The unprecedented pace and scale of AI development demand a regulatory mindset that is not only reactive to emerging risks but also proactively anticipates systemic vulnerabilities before they crystallize into harm. Clear evidence from civil society organisations and public feedback demonstrates that there remains considerable scope to integrate well-founded recommendations into the regulatory framework. These include lessons from the Dutch *SyRI* case—where opacity, disproportionate targeting, and structural discrimination ultimately led to judicial annulment—as well as the critiques outlined in [Section 2.1](#), which emphasise the tangible impact of different regulatory models on cross-border data flows and AI development, and the importance of avoiding competitive disadvantages while upholding robust human rights safeguards. Such insights are not merely cautionary tales; they represent actionable knowledge that can strengthen the AI Act's capacity to protect rights without stifling innovation.

This requires the European Union to embrace a model of governance that is iterative, evidence-driven, and enriched by the sustained involvement of interdisciplinary expertise—from computer science to law, ethics, and the social sciences. Crucially, civil society must remain an integral part of this process, ensuring that lived experiences and rights-based perspectives are embedded into every stage of policy evaluation and reform. If the AI Act's periodic review mechanisms are leveraged with genuine transparency and accountability, they can evolve into a dynamic safeguard—one that continuously recalibrates the balance between innovation and fundamental rights. In doing so, the EU would not merely regulate AI within its borders but set an adaptive, rights-centric global standard, reaffirming that technological progress must serve humanity, not the other way around.

Acknowledgments

This work was supported by the National Research, Development and Innovation Fund, provided by the Hungarian Ministry of Culture and Innovation, under Grant NKKP STARTING_24 (STARTING 150399) programme.

Author contributions

CRedit: **Balázs Hohmann**: Conceptualization, Funding acquisition, Investigation, Methodology, Project administration, Resources, Supervision, Validation, Writing – original draft, Writing – review & editing; **Gergő Kollár**: Conceptualization, Investigation, Resources, Writing – original draft, Writing – review & editing.

Disclosure statement

No potential conflict of interest was reported by the author(s).

Data deposition

No data deposition was required for this study.

Funding

This work was supported by the National Research, Development and Innovation Fund, provided by the Hungarian Ministry of Culture and Innovation, under Grant NKKP STARTING_24 (STARTING 150399) programme.

About the authors

Balázs Hohmann, Ph.D., LL.M., is an assistant professor at the Department of Technology and Energy Law, Faculty of Law, University of Pécs, Hungary. His research focuses on transparency and integrity in administrative procedures, platform and technology law, digital consumer protection, and the legal implications of emerging technologies, including artificial intelligence. He has published extensively in high-quality peer-reviewed journals and authored several monographs, with more than 130 scientific and professional publications overall. He has presented his work at numerous national and international conferences and has participated in several EU- and nationally funded research projects. In addition to his academic work, he is active in professional and civil society organizations, serving as mediator, arbitrator, and editorial board member in international journals.

Gergő Kollár, LL.M., is a research fellow at the Department of Technology and Energy Law, Faculty of Law, University of Pécs, Hungary. His doctoral dissertation, entitled *The Present and Possible Future of European Data Law*, focuses on data protection and data utilization, which are also the core of his broader research interests. He is an active participant in national and international conferences and has taken part in several international research projects. In addition to his academic career, he serves as managing director and lead consultant of Precursor Ltd., a consultancy specializing in data protection and compliance.

ORCID

Balázs Hohmann  <http://orcid.org/0000-0003-4252-1923>

Gergő Kollár  <http://orcid.org/0009-0008-4595-2941>

Data availability statement

There is no data set associated with the study.

References

- AccessNow (2024, March 13). *The EU AI Act: A failure for human rights, a victory for industry and law enforcement*. <https://www.accessnow.org/press-release/ai-act-failure-for-human-rights-victory-for-industry-and-law-enforcement/#:~:text=to%20protect%20people%E2%80%99s%20rights%2C%20the,most%20dangerous%20uses%20of%20AI>
- AccessNow, AlgorithmWatch, Amnesty International, Article 19, Bits of Freedom, European Disability Forum, EDRI (2024, April 3). *EU's AI Act fails to set gold standard for human rights*. <https://edri.org/wp-content/uploads/2024/04/EUs-AI-Act-fails-to-set-gold-standard-for-human-rights.pdf>
- AlgorithmWatch (2020, February 13). *How Dutch activists got an invasive fraud detection algorithm banned*. <https://algorithmwatch.org/en/syri-netherlands-algorithm/#:~:text=The%20Dutch%20government%20has%20been%20using%20SyRI%2C%20a,public%20organizations%20to%20think%20about%20less%20repressive%20alternatives>
- AlgorithmWatch (2024, March 13). *EU Parliament votes on AI Act; member states will have to plug surveillance loopholes*. <https://algorithmwatch.org/en/eu-parliament-votes-on-ai-act/>
- Alqodsi, E. M., & Gura, D. (2023). High tech and legal challenges: Artificial intelligence-caused damage regulation. *Cogent Social Sciences*, 9(2), 2270751. <https://doi.org/10.1080/23311886.2023.2270751>
- Amnesty International (2023, September 13). *AI Act must ban dangerous, AI-powered technologies in historic law*. <https://www.amnesty.org/en/latest/news/2023/09/eu-ai-act-must-ban-dangerous-ai-powered-technologies-in-historic-law/>

- Andrews, C. (2025). *European Commission withdraws AI Liability Directive from consideration*. International Association of Privacy Professionals. <https://iapp.org/news/a/european-commission-withdraws-ai-liability-directive-from-consideration>
- Article 19 (2024, March 13). *EU: AI Act passed in parliament fails to ban harmful biometric technologies*. <https://www.article19.org/resources/eu-ai-act-passed-in-parliament-fails-to-ban-harmful-biometric-technologies/>
- Article 29 Data Protection Working Party (2013, April 2). *Opinion 03/2013 on purpose limitation* (WP 203). European Commission. https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf
- Article 29 Data Protection Working Party (2018, February 6). *Guidelines on Automated individual decision-making and Profiling for the purposes of Regulation 2016/679* (WP251rev.01).
- Aszódi, N. (2025, January 16). *Upcoming Commission guidelines on the AI Act implementation: Human rights and justice must be at their heart* [Joint Statement]. AlgorithmWatch. <https://algorithmwatch.org/en/statement-commission-guidelines-ai-act/>
- Battle, S., & van Waeyenberge, A. (2024). EU-US data privacy framework: A first legal assessment. *European Journal of Risk Regulation*, 15(1), 191–200. <https://doi.org/10.1017/err.2023.67>
- Borak, M. (2024, May 21). *Real-time remote biometrics banned in EU with final green light for AI Act*. Biometric Update. <https://www.biometricupdate.com/202405/real-time-remote-biometrics-banned-in-eu-with-final-green-light-for-ai-act#:~:text=AI%20applications%20with%20unacceptable%20risk,to%20create%20facial%20recognition%20databases>
- Braun, I. (2018). *High-risk citizens*. AlgorithmWatch. <https://algorithmwatch.org/en/high-risk-citizens/>
- Cancela-Outeda, C. (2024). The EU's AI act: A framework for collaborative governance. *Internet of Things*, 27, 101291. <https://doi.org/10.1016/j.iot.2024.101291>
- Chiappetta, A. (2023). Navigating the AI frontier: European parliamentary insights on bias and regulation, preceding the AI Act. *Internet Policy Review*, 12(4), 1–26. <https://doi.org/10.14763/2023.4.1733>
- Chu, X., Ilyas, I. F., Krishnan, S., & Wang, J. (2016). Data cleaning: Overview and emerging challenges. In *Proceedings of the 2016 International Conference on Management of Data* (pp. 2201–2206). Association for Computing Machinery. <https://doi.org/10.1145/2882903.2912574>
- Clifford, D., & Ausloos, J. (2018). Data protection and the role of fairness. *Yearbook of European Law*, 37, 130–187. <https://doi.org/10.1093/yel/yey004>
- Cohen, J. E. (2013). What privacy is for. *Harvard Law Review*, 126(7), 1904–1933.
- Delacroix, S., & Lawrence, N. D. (2019). Bottom-up data trusts: Disturbing the ‘one size fits all’ approach to data governance. *International Data Privacy Law*, 9(4), 236–252. <https://doi.org/10.1093/idpl/ipz014>
- Edwards, L., & Veale, M. (2018). Enslaving the algorithm: From a “Right to an Explanation” to a “Right to Better Decisions”? *IEEE Security & Privacy*, 16(3), 46–54. <https://doi.org/10.1109/MSP.2018.2701152>
- European Commission. (2020). White paper on artificial intelligence: A European approach to excellence and trust. Publications Office of the European Union. https://commission.europa.eu/system/files/2020-02/commission-white-paper-artificial-intelligence-feb2020_en.pdf
- European Center for Not-for-Profit Law (2023, June 14). *Packed with loopholes: Why the AI Act fails to protect civic space and the rule of law*. <https://ecnl.org/news/packed-loopholes-why-ai-act-fails-protect-civic-space-and-rule-law#:~:text=,services%20and%20law%20enforcement%20bodies>
- European Commission (2025a, April 3). *Guidelines on the definition of an artificial intelligence system to facilitate application of the AI Act*. <https://digital-strategy.ec.europa.eu/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application>
- European Commission (2025b, April 3). *Guidelines on prohibited artificial intelligence practices under the AI Act*. <https://digital-strategy.ec.europa.eu/library/commission-publishes-guidelines-prohibited-artificial-intelligence-ai-practices-defined-ai-act>
- European Council (2024, November 8). *Budapest Declaration on the New European Competitiveness Deal*. <https://www.consilium.europa.eu/en/press/press-releases/2024/11/08/the-budapest-declaration/>
- European Disability Forum (2024, February 2). *AI Act agreement: Partial win on accessibility*. <https://www.edf-feph.org/ai-act-agreement-partial-win-on-accessibility/>
- European Parliament (2023, June 8). *EU AI Act: First regulation on artificial intelligence*. <https://www.europarl.europa.eu/topics/en/article/20230601STO93804/eu-ai-act-first-regulation-on-artificial-intelligence>
- Floridi, L. (2021). The end of an era: From self-regulation to hard law for the digital industry. *Philosophy & Technology*, 34(4), 619–622. <https://doi.org/10.1007/s13347-021-00493-0>
- International Organization for Standardization & International Electrotechnical Commission (2019). Information technology—Big data. Overview and Vocabulary (ISO/IEC Standard No. 20546:2019, Section 3.1.2).
- Jabbar, H. K., & Khan, R. Z. (2014). Methods to avoid over-fitting and under-fitting in supervised machine learning (comparative study). In *Proceedings of the 2014 Computer Science, Communication and Instrumentation Devices Conference* (pp. 163–172). https://doi.org/10.3850/978-981-09-5247-1_017
- Lagioia, F., & Sartor, G. (2020). AI Systems Under Criminal Law: a Legal Analysis and a Regulatory Perspective. *Philosophy & Technology*, 33(3), 433–465. <https://doi.org/10.1007/s13347-019-00362-x>
- Jethani, S., Malhotra, P., Ayisha, H., & Nimje, T. (2025, January 20). The closing act of 2024: South Korea's AI Basic Act. TLP Advisors. <https://techlawpolicy.com/2025/01/the-closing-act-of-2024-south-koreas-ai-basic-act/>
- Latour, B. (1999). *Pandora's hope: Essays on the reality of science studies*. Harvard University Press.

- Lehrig, S., Eikerling, H., & Becker, S. (2015). Scalability, elasticity, and efficiency in cloud computing: A systematic literature review of definitions and metrics. In *Proceedings of the 11th International ACM SIGSOFT Conference on Quality of Software Architectures* (pp. 83–92). Association for Computing Machinery. <https://doi.org/10.1145/2737182.2737185>
- Lohr, S. (2012, February 11). The age of big data. *The New York Times*. <https://www.nytimes.com/2012/02/12/sunday-review/big-datas-impact-in-the-world.html>
- Maierà, A. (2023). Broad consent. In V. Colcelli, R. Cippitani, C. Brochhausen-Delius, & R. Arnold (Eds.), *GDPR requirements for biobanking activities across Europe* (pp. 79–86). Springer Nature Switzerland AG. https://doi.org/10.1007/978-3-031-42944-6_9
- Mank, B. C. (2017). Data breaches, identity theft, and Article III standing: Will the Supreme Court resolve the split in the circuits? *Notre Dame Law Review*, 92(3), 1323–1368.
- Mayer-Schönberger, V., & Cukier, K. (2013). *Big data: A revolution that will transform how we live, work, and think*. Houghton Mifflin Harcourt.
- Mccorquodale, R. (1994). Self-Determination: A Human Rights Approach. *International and Comparative Law Quarterly*, 43(4), 857–885. <https://doi.org/10.1093/iclqaj/43.4.857>
- Mejias, U. A., & Coudry, N. (2019). Datafication. *Internet Policy Review*, 8(4), 2–3. <https://doi.org/10.14763/2019.4.1428>
- Misuraca, G., & van Noordt, C. (2020). *Overview of the use and impact of AI in public services in the EU*. Publications Office of the European Union. <https://publications.jrc.ec.europa.eu/repository/handle/JRC120399>
- NOYB (2025). *US Cloud soon illegal? Trump punches first hole in EU-US Data Deal*. <https://noyb.eu/en/us-cloud-soon-illegal-trump-punches-first-hole-eu-us-data-deal>
- Proofed (2023). *What is AI-generated content?* <https://proofed.com/knowledge-hub/what-is-ai-generated-content/>
- Quiñonero-Candela, J., Sugiyama, M., Schwaighofer, A., & Lawrence, N. D. (Eds.). (2009). *Dataset shift in machine learning*. MIT Press. <https://doi.org/10.7551/mitpress/9780262170055.001.0001>
- Schuett, J. (2024). Risk management in the Artificial Intelligence Act. *European Journal of Risk Regulation*, 15(2), 367–385. <https://doi.org/10.1017/err.2023.1>
- Solove, D. J. (2013). Privacy self-management and the consent dilemma. *Harvard Law Review*, 126(7), 1880–1903.
- Southerton, D. (2020). *Time, Consumption and the Coordination of Everyday Life*. Palgrave Macmillan. (pp. 15–23) <https://doi.org/10.1057/978-1-349-60117-2>
- Sun, R., & Treffer, D. (2023). *The impact of AI and cross-border data regulation on international trade in digital services: A large language model* (No. w31925). National Bureau of Economic Research. <https://doi.org/10.3386/w31925>
- Svitych, O. (2025). Blind transparency: A critical discourse analysis of the EU AI Act. *Critical Policy Studies, Latest Articles Collection*, 1–17. <https://doi.org/10.1080/19460171.2025.2496193>
- Szőke, G. L. (2018). Big Data and algorithms in the public sector and their impact on the transparency of decision-making. In H. Hansen, R. Müller-Török, A. Nemeslaki, A. Prosser, D. Scola, & T. Szádeczky (Eds.), *Central and Eastern European eDem and eGov Days 2018: Conference Proceedings* (pp. 301–311). Facultas Verlag. <https://doi.org/10.24989/ocg.v331.25>
- Thomaidou, A., & Limniotis, K. (2025). Navigating through human rights in AI: Exploring the interplay between GDPR and fundamental rights impact assessment. *Journal of Cybersecurity and Privacy*, 5(1), 7. <https://doi.org/10.3390/jcp5010007>
- Tóth, A. (2024). *A digitális átalakulás szabályozása az Európai Unióban [Regulating digital transformation in the European Union]* (pp. 5–15). ORAC.
- Trigueros-Preciado, S., Pérez-González, D., & Solana-González, P. (2013). Cloud computing in industrial SMEs: Identification of the barriers to its adoption and effects of its application. *Electronic Markets*, 23(2), 105–114. <https://doi.org/10.1007/s12525-012-0106-7>
- Wachter, S., Mittelstadt, B., & Russell, C. (2017). Counterfactual explanations without opening the black box: Automated decisions and the GDPR. *SSRN Electronic Journal*, 31(2), 841–887. <https://doi.org/10.2139/ssrn.3063289>
- Zarsky, T. Z. (2013). Transparent predictions. *University of Illinois Law Review*, 2013(4), 1503–1569.
- Zhang, M. (2025, July 9). *The folly of restricting cross-border data flows China-US focus*. China-United States Exchange Foundation. <https://www.chinausfocus.com/finance-economy/the-folly-of-restricting-cross-border-data-flows>
- Zuiderveen Borgesius, F. J. (2020). Strengthening legal protection against discrimination by algorithms and artificial intelligence. *The International Journal of Human Rights*, 24(10), 1572–1593. <https://doi.org/10.1080/13642987.2020.1743976>